

COMP3052.SEC Computer Security

Session 15-4: Cryptology IV

核心:现代密码学=symmetric encryption+asymmetric key exchange+secure modes(对称加密 + 非对称密钥交换 + 安全模式),
即真正系统不是单独AES,而是AES+Diffie-Hellman + TLS + modes of operation



ACKNOWLEDGEMENTS

- Some of the materials we use this semester may come directly from previous teachers of this module, and other sources ...
- Thank you to (amongst others):
 - Michel Valstar, Milena Radenkovic, Mike Pound, Dave Towey...

TOPICS COVERED

- Block Ciphers
 - DES -> AES
 - Modes of Operation
- Public Key Crypto
- Maths ...but don't panic!

WHAT DOES THIS MEAN?

Security Overview



This page is secure (valid HTTPS).

Valid Certificate

The connection to this site is using a valid, trusted server certificate.

[View certificate](#)

Secure Connection

The connection to this site is encrypted and authenticated using a strong protocol (TLS 1.2), a strong key exchange (ECDHE_RSA with P-256), and a strong cipher (AES_128_GCM).

Secure Resources

All resources on this page are served securely.

BLOCK CIPHERS 分组密码

- Block ciphers use a key to encrypt a fixed-size block of plaintext into a fixed-size block of ciphertext 分组密码使用一个密钥将固定大小的明文块加密为固定大小的密文块
->输入固定大小plaintext block,输出固定大小ciphertext block
- They are usually more computationally expensive than stream ciphers, but have numerous benefits 它们通常比流密码在计算上更耗费资源,但具有众多优点
-> 因为需要复杂:substitution,permutation,multiple rounds(替换、排列、多轮操作)
- If you're careful, you can convert between block and stream ciphers using modes of operation 如果你足够谨慎,可以通过操作模式将分组密码和流密码相互转换

BLOCK CIPHERS

- If we change one bit of plaintext in a traditional cipher, one bit of output will **change** 在传统密码系统中，如果我们对明文中的某一位进行修改，那么输出结果中就会相应地出现一位的变化。
- Vulnerable to known and chosen plaintext attacks 易受已知明文和选择明文攻击的影响
- Modern block ciphers are designed to **diffuse changes** throughout **each block** 现代分组密码的设计目的是使变化在每个分组中得到扩散。

核心:plaintext改1 bit,ciphertext:大量bits改变,这叫avalanche effect
为什么diffusion重要? 防止known-plaintext attacks,attacker无法从小变化,推断规律

SP-NETWORKS

SP: Substitution(替换)+permutation(排列)

强cipher只需反复substitution, permutation

Substitution改值,例如A->Q

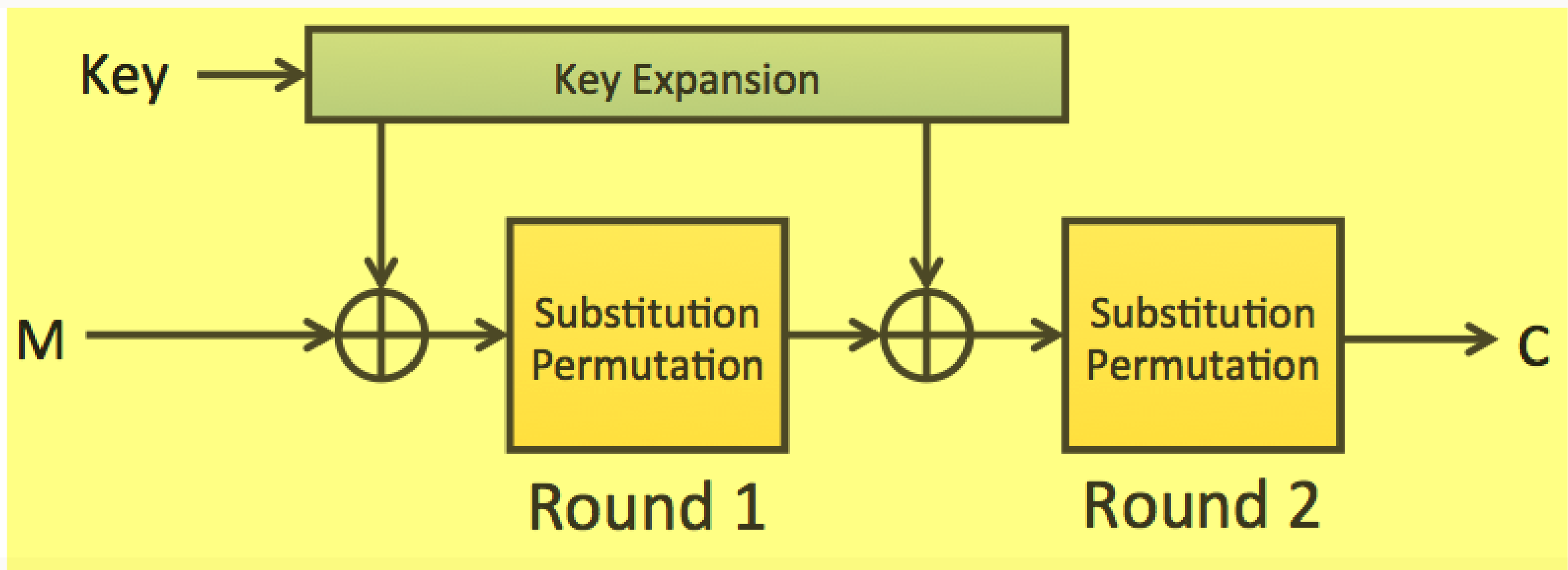
Permutation改位置,例如bit rearrangement

为什么repeated rounds很重要? 一轮不够安全,多轮增加confusion+diffusion

- Claude Shannon suggested that all that was required for a strong cipher was repeated substitution and permutation
要构建一个强大的密码系统,只需要重复进行替换和排列操作即可。
- SP-Networks combine a substitution process with a permutation into a single round
SP 网络将替换过程与排列过程整合为一个完整的轮次。
- Rounds are then repeated enough times to ensure the algorithm is secure
通过重复足够多次的轮次操作,以确保算法的安全性。

SP-NETWORKS

- Can add a key using XOR:



FEISTEL CIPHERS

Feistel是现代block cipher经典结构,特点:多轮结构,每轮处理half blocks
Feistel重要的原因:可用相同结构进行encryption+decryption

- Developed by Horst Feistel in the 1970s at IBM
- Allows us to chain multiple rounds together, using any round function
允许我们将多个轮次串联起来,使用任何轮函数
- The basis of many block ciphers
是许多分组密码的基础
 - Blowfish, DES, CAST-128, GOST 28147-89

LUBY-RACKOFF

Luby-Rackoff核心:well-designed rounds,重复后,可逼近random permutation,即理论证明Feistel可安全

- Mike Luby and Charlie Rackoff showed that if you have **well-designed rounds** (**appear statistically random**) in your Feistel cipher: 其排列形式在统计上是随机的
 - **3 rounds** is sufficient to appear so random that a chosen plaintext attack won't work 3 轮加密就足以做到看似非常随机,以至于选择明文攻击无法奏效。
 - **4 rounds is sufficient** to beat a chosen plaintext *and* ciphertext attack 4 轮加密足以抵御选择明文和密文的攻击。

DATA ENCRYPTION STANDARD

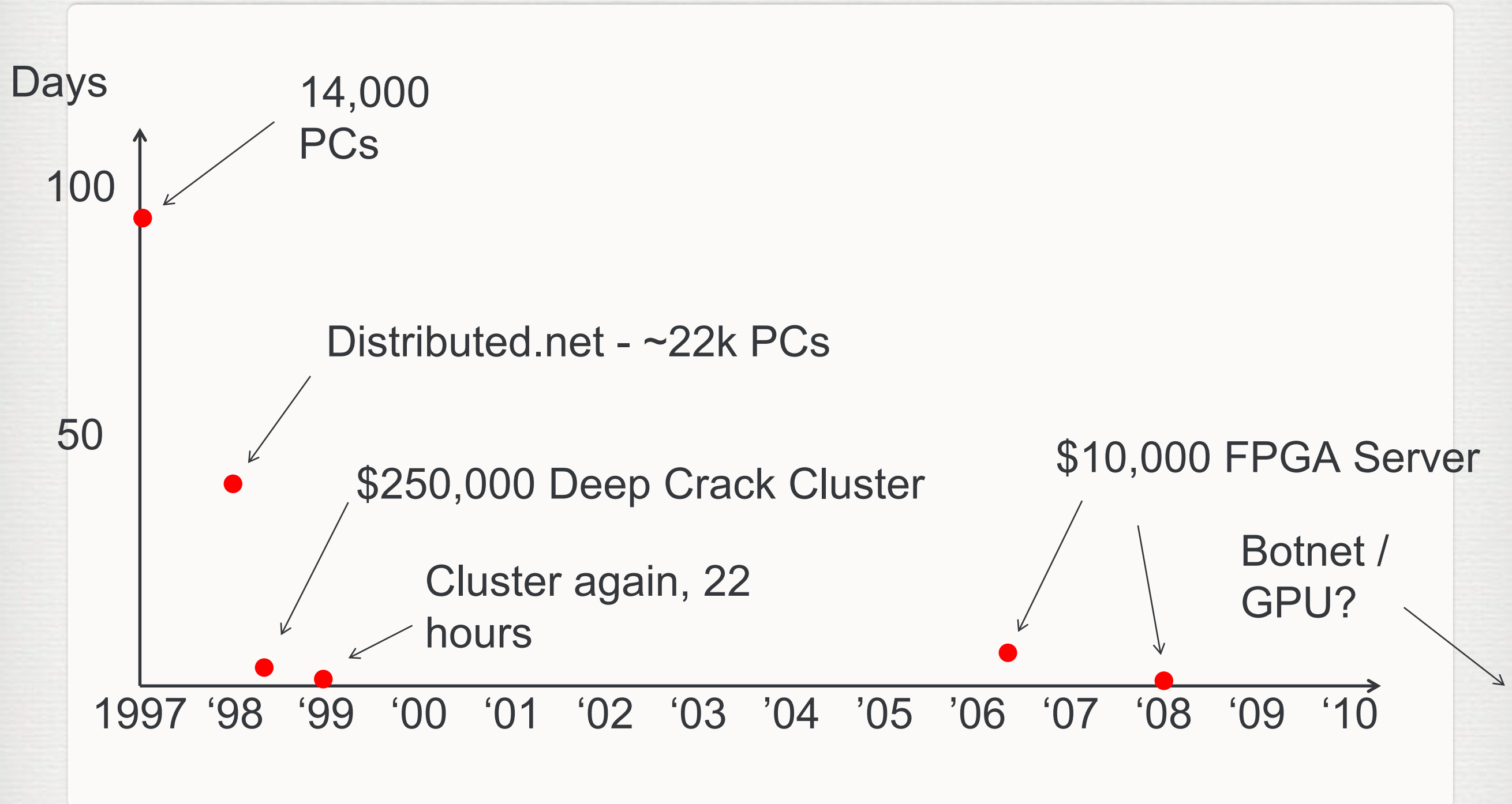
数据加密标准

为什么DES不安全? key太短,brute force现在可行

- DES was, until quite recently, one of the most used symmetric ciphers DES 在不久前还一直是最常用的对称加密算法之一
- It is a 64-bit blocklength, 16 round Feistel cipher, with a 56-bit key 它是一种 64 位块长度、16 轮的费斯泰尔加密算法，使用 56 位密钥
- Developed by IBM in 1970s, with a bit of interference from the NSA 由 IBM 在 20 世纪 70 年代开发，受到了美国国家安全局的一些影响
- Once released, researchers were suspicious of some secrecy regarding the design, and the short key 一经发布，研究人员就对设计的一些保密性以及较短的密钥表示怀疑

CRACKING DES

随着硬件提升,DES破解越来越快->核心:Security changes over time



ADVANCED ENCRYPTION STANDARD

- Superseded DES as a standard in 2002
2002 年取代了 DES 作为标准
- A standard built around the Rijndael algorithm
基于 Rijndael 算法构建的标准
- Rijndael is an SP-Network with a 128-bit block size, and a key length of 128, 192 or 256-bits
Rijndael 是一种具有 128 位块大小和 128、192 或 256 位密钥长度的 SP 网络
- Round count depends on key length
循环次数取决于密钥长度
 - 10, 12 or 14 cycles

AES SECURITY

为什么AES强?

Key space巨大,brute force不现实

- Is currently the standard algorithm for symmetric encryption, and is likely to remain that way

目前这是对称加密的标准算法，而且很可能会一直保持这种状态。

- 2^{128} keys, let's say we get lucky and crack it at 2^{127}

- Let's say 1000 flops per key test, we'd break an AES key in about 30 trillion years

假设每次对密钥的测试有 1000 次失败，那么我们大约需要 30 万亿年才能破解一个 AES 密钥。

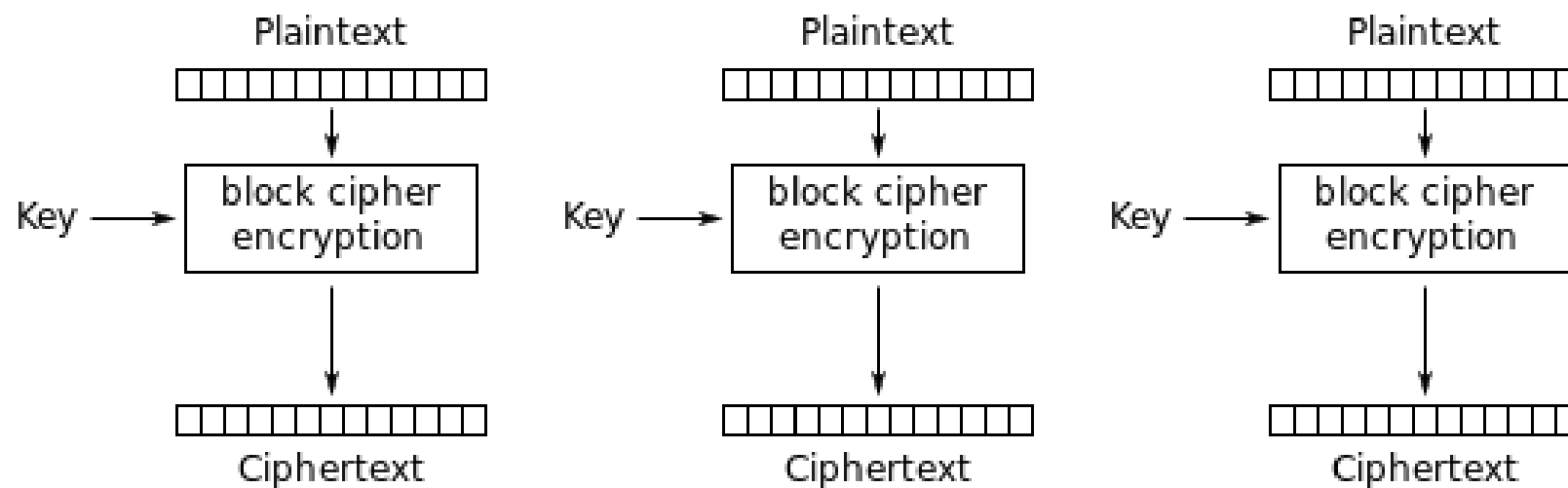
BLOCK CIPHER MODES

Block cipher只能处理固定block,但显示消息长度不同,所以需要modes

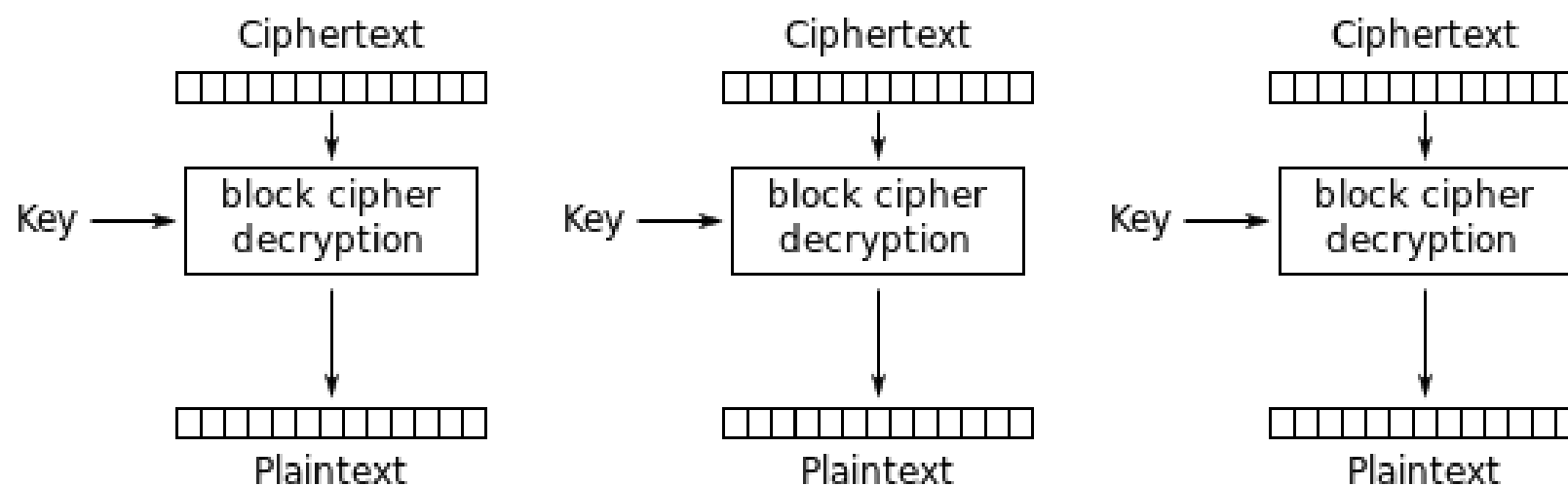
- Most messages aren't in convenient 128-blocks
大多数消息并非以 128 字节为单位进行分块
- Run a block cipher repeatedly on consecutive blocks
对连续的块依次进行分组加密
- Electronic Code Book (ECB) 电子密码本模式->最简单模式,每个block独立加密
ECB最大问题:相同plaintext得到相同ciphertext,patterns泄漏,所以ECB不安全
 - encrypt each block one after another 逐个对每个块进行加密
- Cipher Block Chaining (CBC) 密码块链接模式->每个block依赖前一个ciphertext,即next block depends on previous block
为什么CBC更安全: 相同plaintext不会产生相同ciphertext,patterns被打散
CBC第一个block需要IV (initialization vector), 作用: randomise first block
 - XOR the output of each cipher block with the next input
将每个加密块的输出与下一个输入进行异或运算
- Counter Mode (CTR) 计数器模式->把block cipher变stream cipher
核心:加密counter,得到keystream,然后XOR plaintext
 - Encrypting a counter to produce a stream cipher
通过对计数器进行加密来生成流密码
- Galois Counter Mode (GCM) 伽罗瓦计数器模式
 - Extension of CTR CTR 的扩展模式

GCM基于CTR,但增加authentication/integrity ; TLS常用AES-GCM

ELECTRONIC CODE BOOK

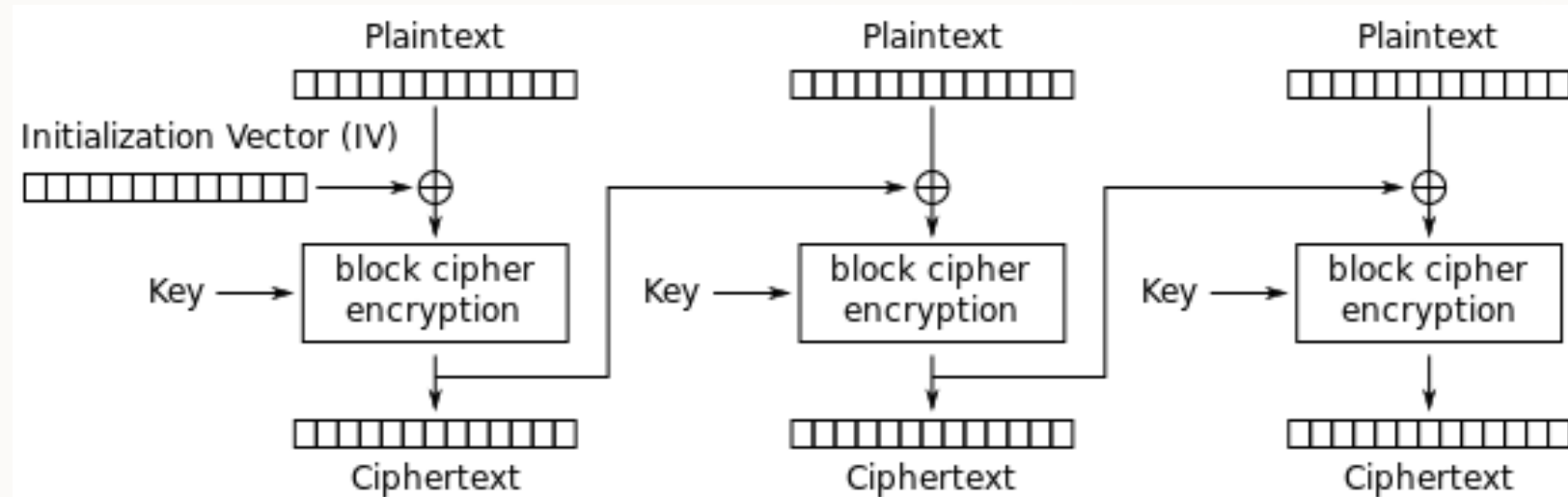


Electronic Codebook (ECB) mode encryption

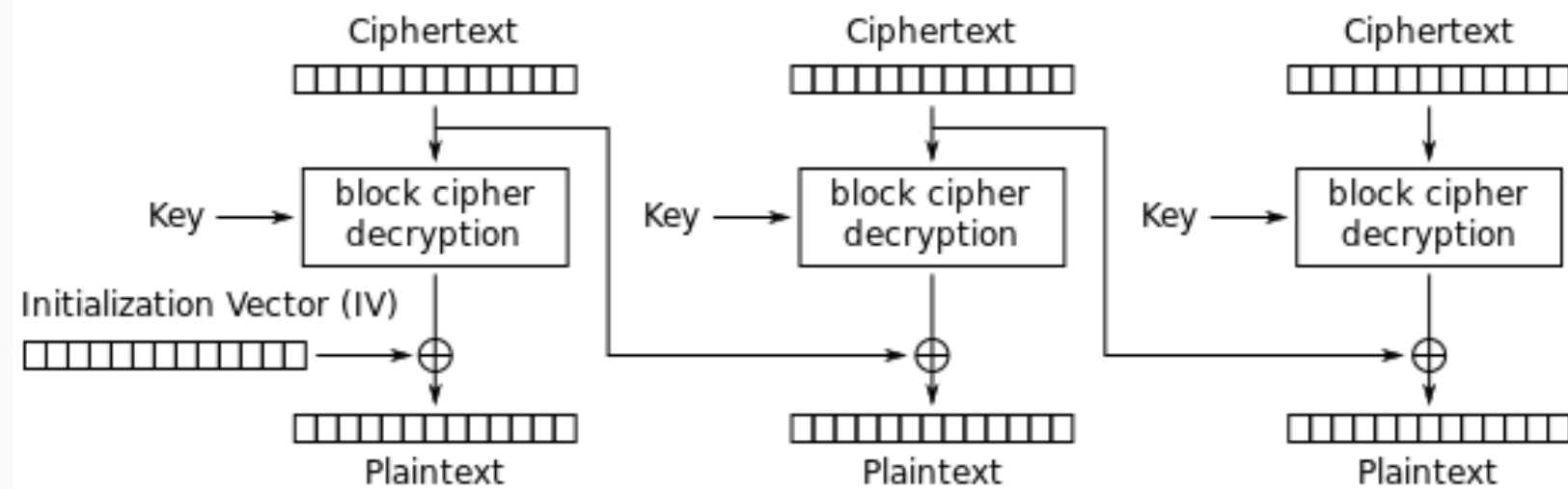


Electronic Codebook (ECB) mode decryption

CIPHER BLOCK CHAINING

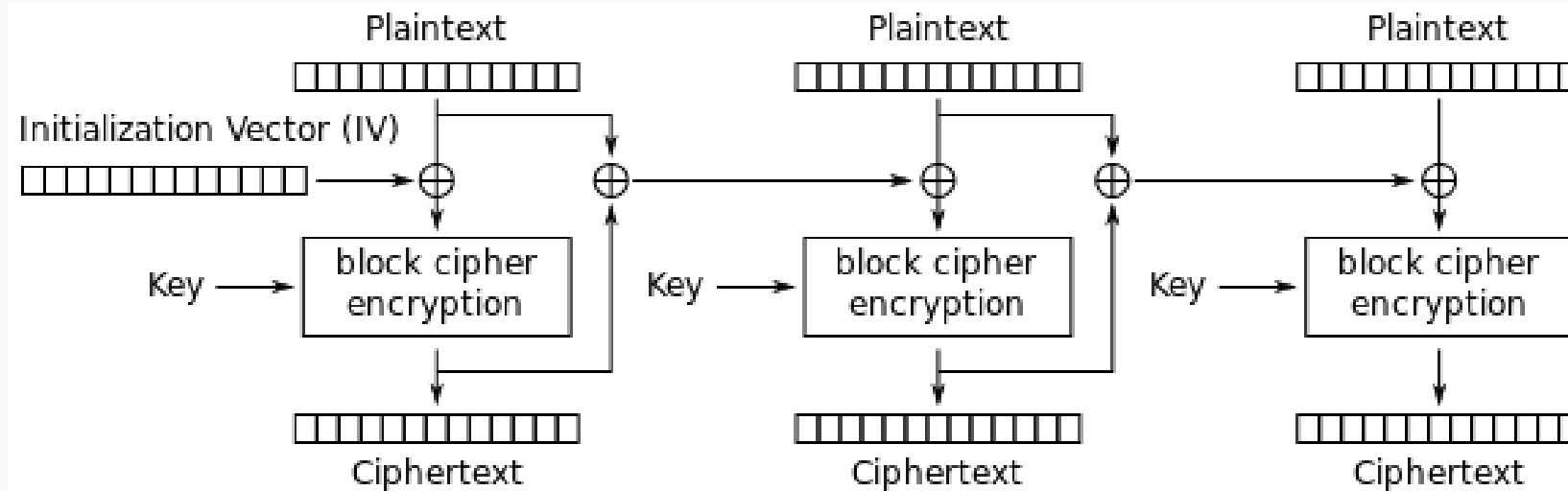


Cipher Block Chaining (CBC) mode encryption

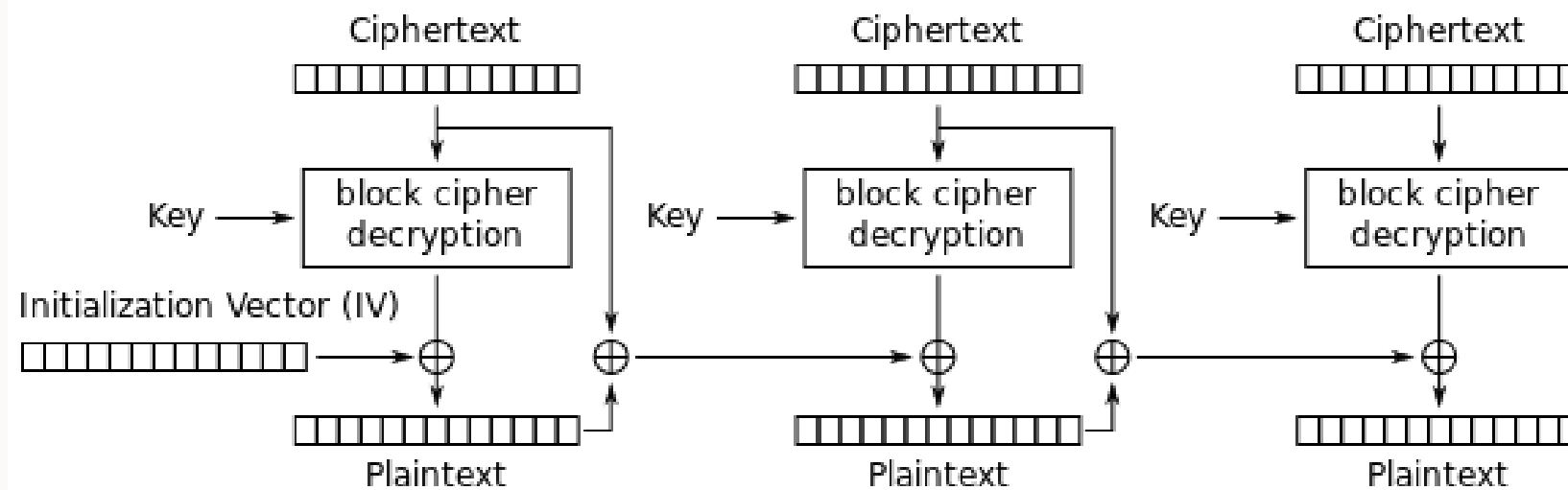


Cipher Block Chaining (CBC) mode decryption

PROPAGATING CBC

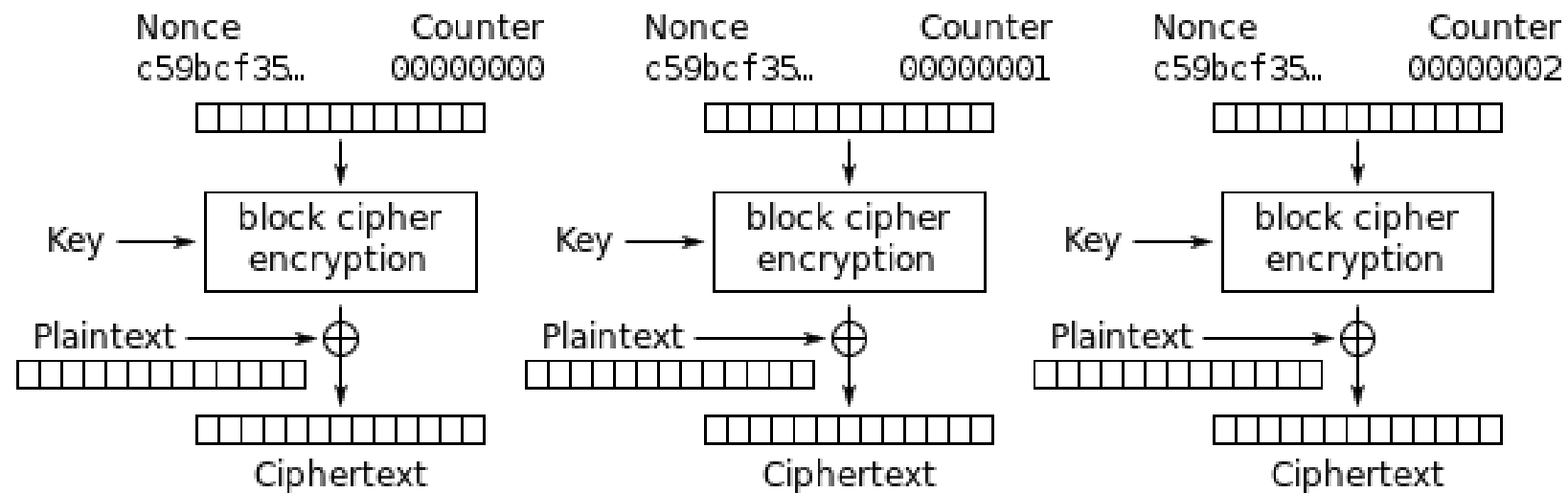


Propagating Cipher Block Chaining (PCBC) mode encryption

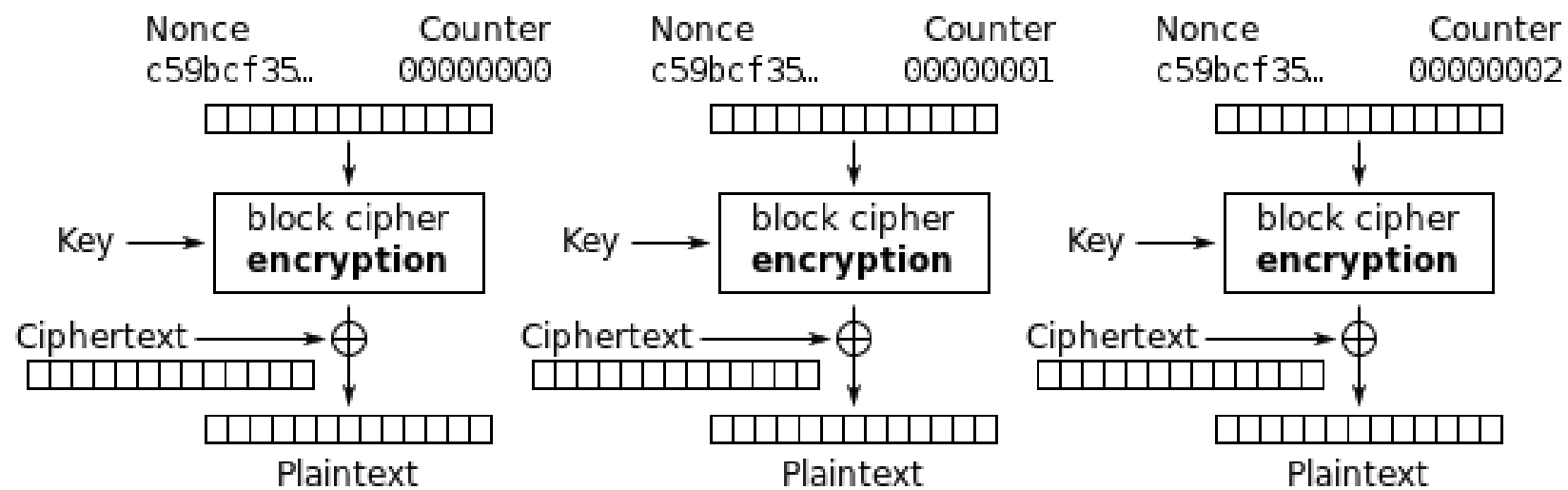


Propagating Cipher Block Chaining (PCBC) mode decryption

COUNTER MODE



Counter (CTR) mode encryption



Counter (CTR) mode decryption

WHAT DOES THIS MEAN?

Security Overview



This page is secure (valid HTTPS).

Valid Certificate

The connection to this site is using a valid, trusted server certificate.

[View certificate](#)

Secure Connection

The connection to this site is encrypted and authenticated using a strong protocol (TLS 1.2), a strong key exchange (ECDHE_RSA with P-256), and a strong cipher (AES_128_GCM).

Secure Resources

All resources on this page are served securely.

Advanced Encryption Standard
(Rjindael)
128-bit Key Size
Galois Counter Mode



WHAT DOES THIS MEAN?

Security Overview



This page is secure (valid HTTPS).

Valid Certificate

The connection to this site is using a valid, trusted server certificate.

[View certificate](#)

Secure Connection

The connection to this site is encrypted and authenticated using a strong protocol (TLS 1.2), a strong key exchange (ECDHE), RSA with P-256, and a strong cipher (AES_128_GCM).

Secure Resources

All resources on this page are served securely.

Advanced Encryption Standard
(Rijndael)
128-bit Key Size
Galois Counter Mode

PUBLIC-KEY CRYPTOGRAPHY

- Two keys, a public key and a private key
- Public-key (asymmetric) cryptography hinges upon the premise that:
公钥（非对称）加密技术基于这样一个基本假设：

*It is computationally infeasible to calculate a private
from a public key*

从公钥推导出私钥在计算上是不可行的。即easy forward, hard backward

- In practice, this is achieved through
intractable mathematical problems
在实际应用中，这是通过难以解决的数学问题来实现的。

WHY?

- Public-key cryptography gains us a few important abilities:
公钥加密技术为我们带来了几个重要的功能：
- We can exchange a private symmetric key “in the open”
我们可以“公开”交换一个私有对称密钥
- We can verify the sender of a message
我们可以验证消息的发送者身份
- Non-repudiation – you can’t deny you did something
不可否认性——你无法否认自己发送了该消息某物

SYMMETRIC VS. ASYMMETRIC

<u>Symmetric</u>	<u>Asymmetric</u>
One Key	Two Keys
Keys are usually 128 or 256-bits	Keys are much longer, 2048 or 4096-bits
Usually extremely fast	Computationally slower
Longer term communication AES	Key exchange, verification and authentication only RSA/DH
Based on circuits of permutation and substitution 排列与替换	Based entirely on mathematical principles

SOME MATHS ...

- Modular Arithmetic
- Exponentiation
- Logarithms
- Discrete Logarithms
- Primitive Roots
- Elliptic Curve Cryptography
- ...

模运算
指数运算
对数
离散对数
原根
椭圆曲线加密技术

Primitive Roots

- The number that is raised to a certain power, is called the **generator g** 被赋予特定幂次的数字，被称为“生成数” g 。

$g = 9$

$$9^1 = 2 \pmod{7}$$

$$9^2 = 4 \pmod{7}$$

$$9^3 = 1 \pmod{7}$$

$$9^4 = 2 \pmod{7}$$

$$9^5 = 4 \pmod{7}$$

$$9^6 = 1 \pmod{7}$$

$g = 3$

$$3^1 = 3 \pmod{7}$$

$$3^2 = 2 \pmod{7}$$

$$3^3 = 6 \pmod{7}$$

$$3^4 = 4 \pmod{7}$$

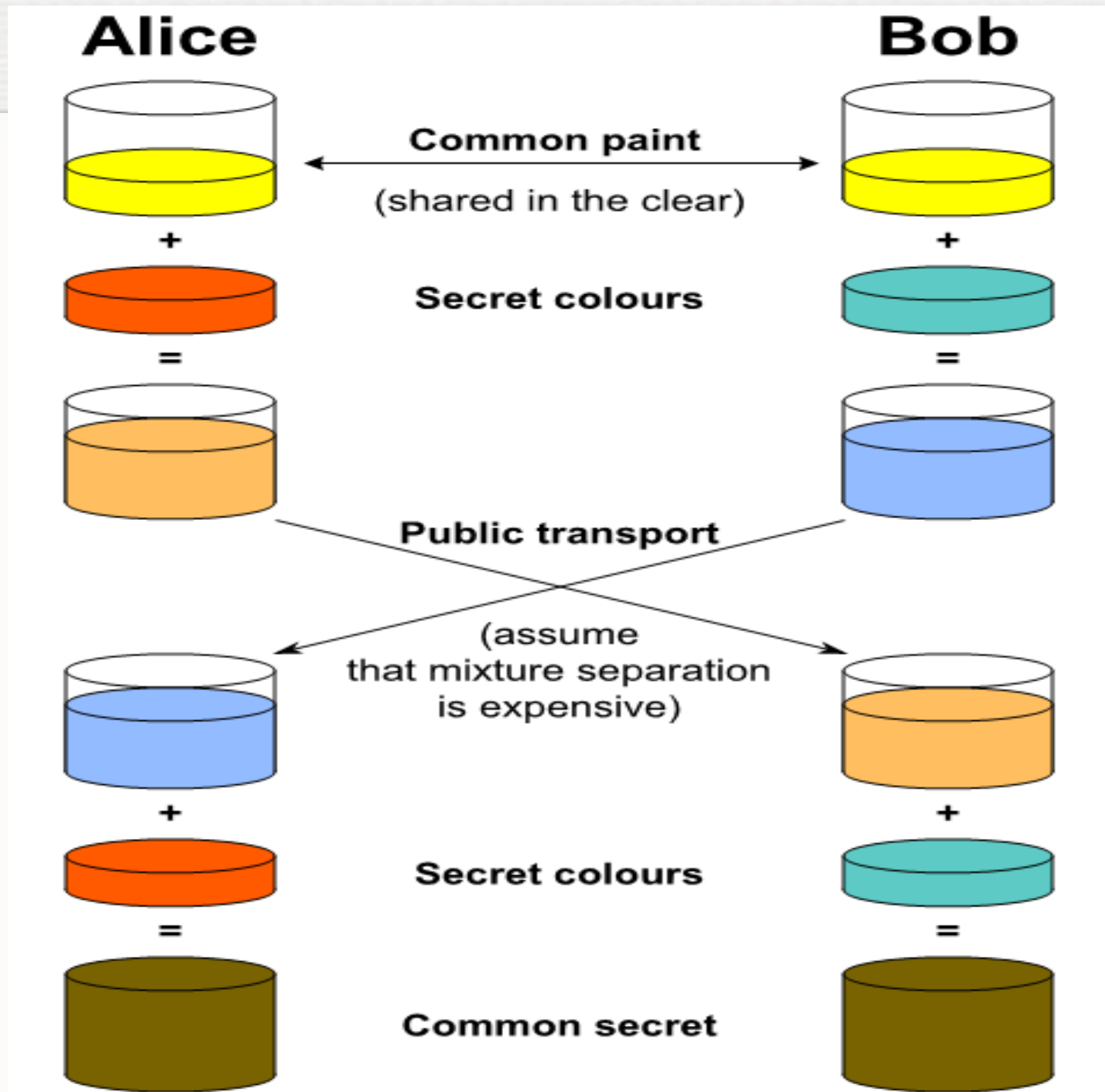
$$3^5 = 5 \pmod{7}$$

$$3^6 = 1 \pmod{7}$$

primitive root



DIFFIE-HELLMAN KEY EXCHANGE



DIFFIE-HELLMAN KEY EXCHANGE

- Diffie-Hellman uses a public-key protocol to exchange a symmetric key in private
迪菲-赫尔曼算法采用公钥协议来交换一个用于加密的对称密钥
- Relies on the difficulty of finding discrete logs
依赖于寻找离散对数的难度

DIFFIE-HELLMAN

艾丽斯和鲍勃共同确定了一个较大的质数 p 以及一个作为 p 的原根的生成数 g

1. Alice and Bob agree on a large prime p , and a generator g that is a primitive root of p
2. Alice chooses a private value a at random, then sends Bob a public $g^a \bmod p$
3. Bob chooses a private value b at random, then sends Alice a public $g^b \bmod p$
4. Alice computes $(g^b)^a \bmod p$, which is actually g^{ab}
5. Bob computes $(g^a)^b \bmod p$, which is also g^{ab}

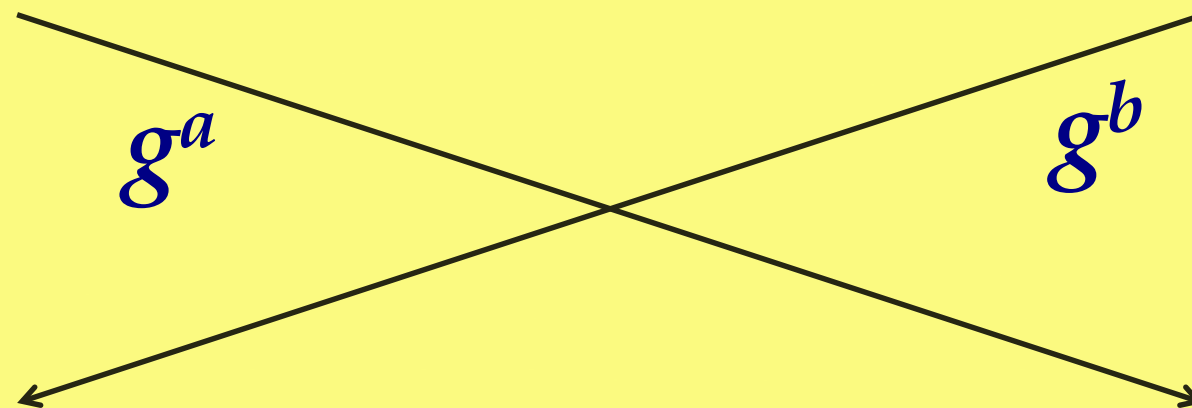
Public, Private

EXAMPLE

Alice and Bob agree on $g = 3$ and $p = 29$

Alice chooses $a = 23$,
then $g^a = 3^{23} \bmod 29 = 8$

Bob chooses $b = 12$, then
 $g^b = 3^{12} \bmod 29 = 16$



Alice calculates:

$$(g^b)^a \bmod 29 = \\ 16^{23} \bmod 29 = 24$$

Bob calculates:

$$(g^a)^b \bmod 29 = \\ 8^{12} \bmod 29 = 24$$

Public, Private

WHY IS DH KEX SECURE?

- The secret shared key is g^{ab}
- Yet, only g , p , g^a and g^b have been transmitted and are public
- The only way to calculate g^{ab} is either $(g^a)^b$ or $(g^b)^a$
- The only way to find a or b is solve:

$$a = \text{dlog}_{g,p}(g^a)$$

$$b = \text{dlog}_{g,p}(g^b)$$

为什么DH安全?

因为依赖discrete logarithm problem, attacker很难反推private exponent

VULNERABILITIES

DH本身不认证身份,所以可能MITM attack, attacker建立两个separate keys

- **Man-in-the-middle** 中间人攻击
 - A third party could intercept the initial communication from Alice, then create two separate key exchanges with both Alice and Bob
第三方可以拦截爱丽丝的初始通信, 然后与爱丽丝和鲍勃分别进行两次独立的密钥交换
 - Simply re-encrypting each message would allow them to sit in the middle of the conversation 仅仅对每条消息进行重新加密就能让他们处于对话的中间位置
 - We can avoid this by combining DH with another cryptographic protocol
我们可以通过将 DH 与另一种加密协议相结合来避免这种情况

PERFECT FORWARD SECRECY

完全前向保密性

PFS:每次session建立新key, 即使长期key泄漏, 旧session仍安全

- There's always a chance a DHKEX key might be broken

如果一个 DHKEX 密钥有可能被破解, 那该怎么办?

- If we establish a symmetric key, how long should we use it for?

如果我们建立一个对称密钥, 我们应该使用它多久呢?

- Perfect forward secrecy means we generate new keys for each session, rather than persistent keys

完全前向保密性意味着我们为每个会话生成新的密钥, 而不是使用持久性密钥。

EPHEMERAL MODE 临时模式

TLS现在推荐ephemeral DH, 即temporary keys

在像 TLS 这样的协议中, 将迪菲—赫尔曼算法设置为临时模式会每次启动时都进行新的密钥交换

- In protocols like TLS, running Diffie-Hellman in ephemeral mode forces a new key exchange every time
- The recommended settings for TLS are now 2048-bit DH keys, in ephemeral mode

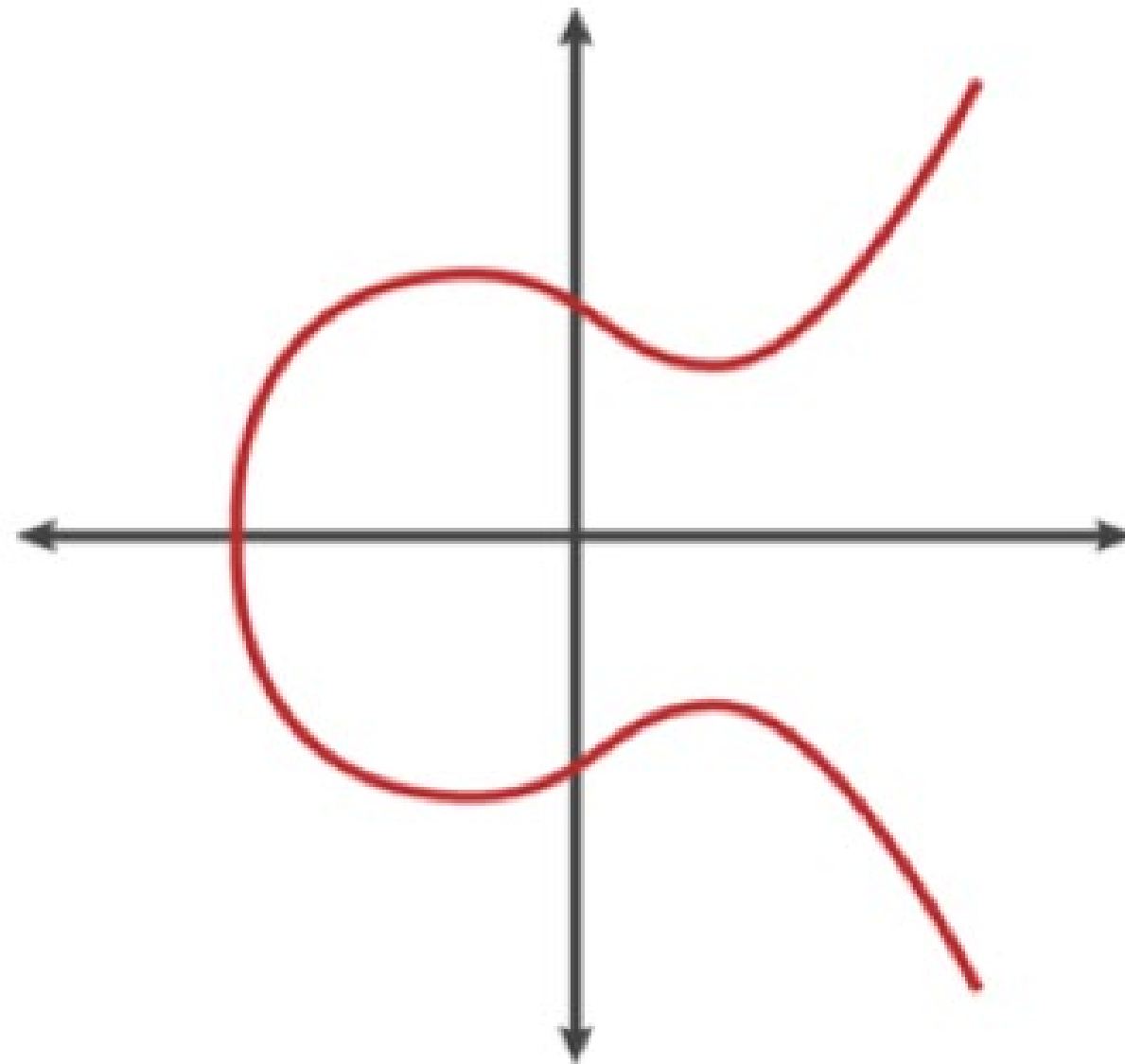
目前, TLS 的推荐设置是使用 2048 位的迪菲—赫尔曼密钥, 并采用临时模式。

ELLIPTIC CURVE CRYPTOGRAPHY

椭圆曲线加密技术

基于elliptic curve discrete logs, 优点:smaller keys同等安全性

- Elliptic curves, of the form $y^2 = x^3 + ax + b$ can be used in place of mod arithmetic in DHKEX



ELLIPTIC CURVE CRYPTOGRAPHY

- Elliptic curve Diffie-Hellman is very similar to the regular version, but instead of $g^a \bmod p$ we calculate $aG \bmod p$, so $G + G + G \dots a$ times

椭圆曲线迪菲-赫尔曼算法与常规算法非常相似，不过我们不是用“ $g \bmod p$ ”来进行计算，而是计算“ $aG \bmod p$ ”，其中 G 是一个基础元素， a 是一个整数，而“..... a 次”则表示重复加法运算的次数。

- Given another point on the curve P , and the generator G , it is extremely hard to calculate a where

假设曲线上的另一点为 P ，且有生成元 G ，那么要计算出 a （使得 $P = aG$ ）则极其困难。

$$P = aG$$

- This is the elliptic curve discrete logarithm problem

这就是椭圆曲线离散对数问题。

WHAT DOES THIS MEAN?

Security Overview



This page is secure (valid HTTPS).

Valid Certificate

The connection to this site is using a valid, trusted server certificate.

[View certificate](#)

Secure Connection

The connection to this site is encrypted and authenticated using a strong protocol (TLS 1.2), a strong key exchange (ECDHE_RSA with P-256), and a strong cipher (AES_128_GCM).

Elliptic Curve
Diffie-Hellman
Ephemeral

Secure Resources

All resources on this page are served securely.

Advanced Encryption Standard
(Rijndael)
128-bit Key Size
Galois Counter Mode

SUMMARY

- Block Ciphers
 - DES -> AES
 - Modes of Operation
- Public Key Crypto
- (some) maths

Read:

- Gollman: Chapter 14
- Anderson: Chapter 5